

MERIDIAN TRUST & ASSET SERVICING, N.A.

Office of the Chief Risk Officer · Model Risk Management

STD-AI-002

Enterprise AI Governance Standard

Governance of artificial intelligence systems outside the scope of Policy MRM-014

Document number	STD-AI-002
Version	2.1
Classification	Internal — Restricted
Document owner	Chief Risk Officer
Effective	First day of current cycle
Review cycle	Annual
Approved by	Board Risk Committee

Contents

Document Control	1
Revision history	2
Distribution	2
Related documents	3
1. Purpose	3
2. Scope	3
2.1 Systems in scope	3
2.2 Systems out of scope	4
2.3 The scope boundary is not a governance boundary	4
2.4 Composite systems	4
3. Authority and Enforcement	5
4. The Non-Delegation Principle	5
5. Definitions	
6. Governance Structure	7
6.1 Board Risk Committee	7
6.2 Executive Risk Committee	7
6.3 Model Risk Committee (MRC)	7
6.4 Fiduciary Risk Committee (FRC)	7
6.5 Trust Investment Committee (TIC)	7
6.6 AI Systems Governance Sub-Committee (AISGC)	7
6.7 Operational Risk & Technology Committee (ORTC)	
7. Registration and the Central AI & Model Inventory	
7.1 Registration is a precondition	8
7.2 Retrospective registration	8
7.3 The intake schema	8
7.4 Accuracy of registration	8
7.5 Foundation-model registration	8
7.6 Research registration	8
8. Risk Tiering	9

8.1 Method	9
8.2 Dimensions, weights, and scoring criteria	9
8.3 Thresholds	9
8.4 Mandatory overrides	10
8.5 Scoring integrity	10
8.6 Worked example — Tier 3 determination	10
8.7 Worked example — Tier 1 determination with owner divergence	10
9. The Eight Required Controls	11
9.1 Application	11
9.2 Proportionality	11
9.3 Inherited evidence	11
9.4 Unsupported assertions	11
Control 1 — Hallucination and confabulation testing	11
Control 2 — Prompt injection and adversarial resistance	12
Control 3 — Data leakage and privacy	13
Control 4 — Harmful bias and differential treatment	
Control 5 — Retrieval grounding	14
Control 6 — Human oversight	15
Control 7 — Third-party and foundation-model risk	16
Control 8 — Ongoing monitoring and drift	16
9.5 Control assessment summary format	17
10. Validation	17
10.1 Principle	17
10.2 Tier 1 — full independent validation	17
10.3 Tier 2 — targeted validation	17
10.4 Tier 3 — streamlined verification	
10.5 Revalidation	18
10.6 Review capacity analysis	18
11. Deployment and Change	18
12. Recordkeeping	18
12.1 Application of 12 CFR § 9.8	18
12.2 What must be retained	18
12.3 A saved output is not a record	19

12.4 Retention and integrity	19
13. Monitoring	19
14. Fiduciary Overlay	19
15. Third Parties and the AI Bill of Materials	20
16. Exceptions, Waivers, and Retirement	20
17. Findings and Remediation	21
17.1 Severity levels	21
17.2 Severity is assessed, not inherited	21
17.3 Accountability	21
17.4 Overdue findings	
18. Reporting	21
19. Training and Attestation	22
Appendix A — CAIMI Intake Schema	23
Appendix B — Evidence Matrix by Tier	25
Appendix C — Approval	25

Document Control

Document number	STD-AI-002
Document type	Enterprise Standard (subordinate to Policy MRM-014 and Policy ERM-001)
Version	2.1
Status	Approved — in force
Classification	Internal — Restricted
Document owner	Chief Risk Officer
Delegated custodian	Head of Model Risk Management
Administering body	AI Systems Governance Sub-Committee (AISGC)
Approving body	Board Risk Committee
Effective date	First day of current cycle
Next scheduled review	Annual, or upon material change to supervisory guidance
Applies to	All legal entities, divisions, branches, and subsidiaries of Meridian Trust & Asset Servicing, N.A., and to all contractors and third parties developing or operating AI systems on the Bank's behalf

Revision history

Version	Date	Author	Summary of change	Approved by
0.1	Cycle – 3, Q2	Model Risk Officer, AI	Initial draft circulated for comment	—
0.9	Cycle – 3, Q4	Model Risk Officer, AI	Incorporated Internal Audit and Legal comment; added third-party section	—
1.0	Cycle – 2, Q1	Head of MRM	Initial issuance establishing the GenAI Governance Track	Board Risk Committee
1.1	Cycle – 2, Q3	Head of MRM	Clarified scope boundary with MRM-014 for composite systems	Model Risk Committee
2.0	Cycle – 1, Q2	Head of MRM	Extended scope to agentic workflows; introduced mandatory AIBOM; restructured tiering to six weighted dimensions	Board Risk Committee
2.1	Current cycle, Q1	Model Risk Officer, AI	Added fiduciary-capacity overlay (§ 14); added impartiality requirement to Control 4; added § 12 recordkeeping provisions following Internal Audit finding IA-2026-031	Board Risk Committee

Distribution

Board Risk Committee · Board Audit Committee · Executive Risk Committee · Model Risk Committee · Fiduciary Risk Committee · Trust Investment Committee · AI Systems Governance Sub-Committee · Operational Risk & Technology Committee · Internal Audit · Office of the General Counsel · Chief Data Officer · All 1LOD system owners registered in CAIMI

Related documents

Reference	Title
MRM-014	Model Risk Management Policy
ERM-001	Enterprise Risk Management Policy
REF-FID-003	Defined Terms — Fiduciary, Custody, and Asset Servicing
FOM-01	Fiduciary Operations Manual
POL-DP-007	Data Privacy and Protection Policy
POL-TPR-004	Third-Party Risk Management Policy
POL-IS-002	Information Security Policy
POL-REC-001	Records Management and Retention Policy
SOP-AI-001	AI Use-Case Registration Procedure
SOP-AI-002	Independent Validation Procedure
SOP-AI-003	AI Incident Escalation Procedure

1. Purpose

1.1 This Standard establishes mandatory requirements for the governance, registration, validation, deployment, monitoring, and retirement of artificial intelligence systems that fall outside the formal definition of "model" set out in Policy MRM-014.

1.2 It exists because the Bank concluded, at the direction of the Board Risk Committee, that the exclusion of generative and agentic artificial intelligence from prevailing supervisory model-risk definitions creates a governance gap that the Bank must close on its own authority rather than await guidance to close.

1.3 The Standard is written to be examinable. Each requirement is stated so that a supervisor, an internal auditor, or an independent validator can determine whether the Bank has met it, and so that the evidence demonstrating compliance is identified at the point the requirement is stated.

2. Scope

2.1 Systems in scope

This Standard applies to any system, capability, or workflow that:

(a) generates natural language, code, images, audio, or structured output using a foundation model, large language model, or other generative architecture;

- (b) performs semantic retrieval, embedding, vector search, or retrieval-augmented generation over Bank or client information;
- (c) executes multi-step reasoning, planning, or tool invocation on behalf of a user or process, whether described as an agent, a copilot, an assistant, or an automation;
- (d) classifies, extracts, summarises, or transforms unstructured content where the output informs a Bank decision, a client communication, or a record required to be maintained; or
- (e) any combination of the above.

2.2 Systems out of scope

This Standard does not apply to:

- (a) systems meeting the definition of "model" in MRM-014, which remain governed exclusively by that Policy;
- (b) deterministic rule engines, decision tables, and business-rule management systems that contain no learned component;
- (c) commercial off-the-shelf software containing embedded AI features that the Bank cannot configure, cannot direct at Bank or client data, and does not rely upon for any decision, provided the exclusion is registered and reviewed annually under § 16.4;
- (d) research, experimentation, and proof-of-concept work conducted exclusively against synthetic or public data in a non-production environment, provided no output informs any Bank decision and the work is registered under § 7.6.

2.3 The scope boundary is not a governance boundary

2.3.1 Exclusion from the formal definition of "model" under prevailing supervisory guidance is **not** exclusion from governance. Where model-risk guidance does not reach a system, this Standard does.

2.3.2 The Bank's position, recorded in the minutes of the Board Risk Committee and stated here for the avoidance of doubt, is that the risk a system presents is determined by what it affects and how irreversibly, not by whether it satisfies a definitional test.

2.4 Composite systems

2.4.1 A system that combines a generative component with a component in scope of MRM-014 is governed **concurrently** under both instruments. Neither is sufficient alone.

2.4.2 Examples of composite systems, provided as interpretive guidance and not as an exhaustive list:

- (a) a language model that retrieves the output of a quantitative valuation engine in order to draft a client memorandum — the valuation engine is governed by MRM-014, the retrieval and drafting layer by this Standard, and the composite by both;
- (b) an agentic workflow that invokes a credit or counterparty scoring model as a tool;
- (c) a generative summarisation layer presented on top of a regulatory capital calculation.

2.4.3 Where governance requirements conflict, the more stringent applies. Where accountability is ambiguous, the Model Risk Committee resolves it and records the resolution.

3. Authority and Enforcement

3.1 This Standard is issued under the authority of the Board Risk Committee pursuant to Policy ERM-001 § 4.2.

3.2 Compliance is mandatory. A system operating in breach of this Standard is operating without authorisation, and the Head of Model Risk Management may direct its suspension without prior consultation with the business.

3.3 The authority at § 3.2 has been exercised. It is recorded here so that no system owner may claim surprise.

3.4 Deliberate circumvention — including registering a system under a description that understates its capability, its data access, or its fiduciary capacity — is a conduct matter referred to Human Resources and the Office of the General Counsel.

4. The Non-Delegation Principle

4.1 The Bank exercises fiduciary powers granted under 12 U.S.C. § 92a and administered under 12 CFR Part 9. Those powers carry duties of prudence, loyalty, and impartiality that attach to the Bank as trustee.

4.2 **Those duties cannot be delegated to an automated process.** An artificial intelligence system is, in every circumstance contemplated by this Standard, an operational tool or a decision-support mechanism. It is never the fiduciary, and it is never the decision-maker of record.

4.3 Accordingly, every output of an AI system that informs a discretionary decision, an asset movement, a fee assessment, a client communication, or an account review requires:

- (a) documented procedural prudence in the design and validation of the system that produced it;
- (b) independent validation proportionate to the assigned risk tier;
- (c) adjudication by a named human officer with the authority, the information, and the practical opportunity to reach a different conclusion; and
- (d) a record sufficient to reconstruct both the system's contribution and the officer's disposition of it.

4.4 Delegation of the work does not delegate the duty. A trust officer who adopts a generated recommendation has made that recommendation their own, and the Bank is answerable for it as if no system had been involved.

4.5 It follows that a human review step which the reviewer lacks the time, the information, or the standing to perform meaningfully does not satisfy § 4.3(c). Review capacity is a control, and § 10.6 requires it to be evidenced rather than asserted.

5. Definitions

For the purposes of this Standard the following definitions apply. Terms defined in REF-FID-003 carry the meaning given there and are not repeated. Where a term is defined both here and in MRM-014, this Standard governs for systems in its scope.

Adjudication — the act by which a named human officer accepts, modifies, or rejects a system output and assumes responsibility for the result.

Agentic workflow — a system that decomposes an objective into steps, selects among available tools or actions, and executes more than one step without returning to a human between steps.

AI Bill of Materials (AIBOM) — the machine-readable inventory of a system's model, data, retrieval, guardrail, and dependency components, maintained per § 15.

AI system — a system that infers, from input, how to generate outputs such as predictions, content, recommendations, or decisions.

Automation level — one of: *strict human-in-the-loop*, meaning mandatory human sign-off on every output with no exception path; *human-on-the-loop*, meaning human review of exceptions only, with unreviewed outputs proceeding; or *autonomous execution*, meaning output proceeds without human review.

Central AI & Model Inventory (CAIMI) — the Bank's system of record for registered AI systems and models.

Chunk — a contiguous span of a source document, as divided for embedding and retrieval.

Faithfulness — the proportion of distinct factual assertions in a generated output that are substantiated by the retrieved context supplied to the model. Also termed *groundedness*.

Foundation model — a large pre-trained model, typically third-party, registered once as a shared component and relied upon by multiple use cases.

Golden dataset — a frozen, version-controlled set of inputs with human-adjudicated correct outputs and correct source passages, used for evaluation. A golden dataset that is modified is a new golden dataset and carries a new version.

Guardrail — a deterministic control applied to model input or output that is not itself a model, and whose operation does not depend on the model's cooperation.

Impartiality impact — the property of a system whose output can affect the allocation of benefit between two or more beneficiary classes of the same account, including between current income beneficiaries and remaindermen.

Reversibility — one of: *fully reversible (T+0)*, meaning the effect can be undone within the business day by the Bank acting alone; *conditionally reversible*, meaning reversal requires counterparty or client cooperation or falls outside the business day; or *irreversible execution*, meaning reversal requires judicial process or is not available.

Unsupported control — a control asserted as satisfied but without a citation to a retrievable document and section. An unsupported control is recorded as a gap. See § 9.4.

Use case — a specific business application of a foundation model. One foundation model supports many use cases; each is registered and tiered separately.

6. Governance Structure

6.1 Board Risk Committee

Approves this Standard and material amendments to it. Acts as final approver for production release of any Tier 1 system. Receives quarterly reporting under § 18.

6.2 Executive Risk Committee

Chaired by the Chief Risk Officer. Holds aggregate AI risk appetite and resolves escalations between the committees below.

6.3 Model Risk Committee (MRC)

Chaired by the Head of Model Risk Management. Approves validation outcomes, tier determinations, and remediation plans for systems in scope of MRM-014, and for composite systems jointly with the AISGC. Resolves scope ambiguity under § 2.4.3.

6.4 Fiduciary Risk Committee (FRC)

Chaired by the Chief Fiduciary Officer. Holds non-delegable authority over activities conducted in a fiduciary capacity. **No system carrying fiduciary capacity or impartiality impact may enter production without FRC sign-off**, irrespective of any other approval obtained.

6.5 Trust Investment Committee (TIC)

Reports to the FRC. Maintains approved lists and investment policy standards, and oversees the conduct and completeness of reviews under 12 CFR § 9.6(c), including any automated contribution to them.

6.6 AI Systems Governance Sub-Committee (AISGC)

Joint 1LOD / 2LOD membership, chaired alternately. Administers this Standard. Reviews use-case intake, tier determinations, AIBOMs, guardrail audits, and exception requests. Meets no less than monthly. Minutes are retained under POL-REC-001.

6.7 Operational Risk & Technology Committee (ORTC)

Owns third-party vendor risk under POL-TPR-004 and cyber resilience. Concurs on foundation-model supplier onboarding under § 15.

7. Registration and the Central AI & Model Inventory

7.1 Registration is a precondition

7.1.1 No AI system may be developed beyond proof of concept, connected to a production data source, granted access to client or beneficiary information, or used to support any Bank decision until it is registered in CAIMI.

7.1.2 The registration sequence is absolute: **registration precedes validation; validation precedes production**. There is no expedited path and no provisional production status.

7.2 Retrospective registration

7.2.1 A system discovered in production without registration is registered retrospectively and simultaneously recorded as a Level 2 finding under § 17.

7.2.2 Retrospective registration does not cure the deficiency and does not authorise continued operation. The AISGC determines whether the system may continue to operate during remediation, and records the basis for that determination.

7.3 The intake schema

Registration captures the fields at Appendix A across seven dimensions: identification, functional design, data classification, fiduciary scope, human oversight, supply chain, and sign-off. Every field is mandatory. "Unknown" is a permitted value only where Appendix A marks the field as discoverable during validation, and every such value generates a validation objective.

7.4 Accuracy of registration

7.4.1 The registered description is the description against which the system is validated, monitored, and examined. A system that has outgrown its registration is an unregistered system.

7.4.2 Material change — to purpose, data classes, integration endpoints, automation level, foundation model or version, or fiduciary capacity — requires re-registration and re-tiering before the change reaches production. § 16.2 governs.

7.5 Foundation-model registration

A foundation model is registered once as a shared component with an AIBOM. Registration of the shared component does not register any use case built on it, and evidence held at the shared-component level does not satisfy a use-case-level control unless this Standard expressly says so.

7.6 Research registration

Research and proof-of-concept work excluded under § 2.2(d) is registered in a lightweight research register maintained by the AISGC, recording the sponsor, the data used, and an attestation that no production data is in scope and no output informs a Bank decision. The register is reviewed at each AISGC meeting for items that have quietly become production.

8. Risk Tiering

8.1 Method

Inherent risk is scored across six dimensions. Each dimension is scored 1, 3, or 5 against the criteria at § 8.2. The weighted sum determines the tier, subject to the mandatory overrides at § 8.4.

$$\text{Inherent Risk Score} = \sum_{j=1}^6 w_j s_j$$

8.2 Dimensions, weights, and scoring criteria

Dimension	Weight	Score 1	Score 3	Score 5
Fiduciary & legal exposure	0.25	Back-office or internal function; no fiduciary duty attaches	Agency custody, directed fiduciary, or regulatory-adjacent process	Discretionary fiduciary under 12 CFR Part 9 or ERISA; impartiality implicated
Data sensitivity & privacy	0.20	Public filings, market data, operational identifiers	Internal operational or desk-level metrics	Beneficiary or client PII, health or family-wealth data, MNPI
Autonomy & human oversight	0.20	Strict human-in-the-loop, no exception path	Human-on-the-loop, exception-only review	Autonomous execution
Operational reversibility	0.15	Fully reversible internal update	Same-day reversal available (T+0)	Irreversible external execution
Model complexity	0.10	Deterministic extraction or classification with fixed outputs	Supervised classification	Generative, fine-tuned, retrieval-augmented, or agentic
Financial & volumetric exposure	0.10	Low aggregate impact	Moderate aggregate impact	Portfolio-level or franchise-level impact

8.3 Thresholds

Tier	Score	Validation	Approval	Monitoring
Tier 1 (High)	≥ 3.80	Full independent 2LOD validation per § 10.2	MRC and FRC where fiduciary; BRC final	Continuous; annual or event-driven revalidation
Tier 2 (Moderate)	2.50 – 3.79	Targeted outcomes validation per § 10.3	Head of MRM	Quarterly KRI tracking
Tier 3 (Low)	< 2.50	Streamlined verification per § 10.4	System owner with 2LOD concurrence	Annual line-of-business review

8.4 Mandatory overrides

A system is **Tier 1 irrespective of computed score** where any of the following is true:

(a) it operates in a discretionary fiduciary capacity; (b) it carries impartiality impact; (c) it processes beneficiary or client PII, health data, or MNPI; (d) it can cause irreversible execution; (e) it contributes to a review required under 12 CFR § 9.6(c); (f) it generates content delivered to a client, beneficiary, or plan participant without individual human review of each item.

8.5 Scoring integrity

8.5.1 The system owner produces a self-assessment. The assigned 2LOD reviewer produces an independent score. **Where they differ, the 2LOD score governs**, and both scores are retained in the registration record with the basis for each.

8.5.2 Retention of both scores is deliberate. The pattern of divergence between first-line and second-line scoring is itself a risk indicator, reported under § 18.3.

8.5.3 The following reasoning is expressly rejected as a basis for reducing a dimension score, having been observed in practice:

- (a) that downstream committee review converts a discretionary capacity into a directed one — it does not; the capacity is determined by the instrument and by law, not by the Bank's internal workflow;
- (b) that the availability of an accounting adjustment makes an executed payment reversible — an accounting entry and a disbursed wire are different facts;
- (c) that per-transaction size is small — exposure is assessed in aggregate across the population the system touches;
- (d) that a human "can" review each output — the question is whether review occurs with effect, which § 10.6 requires to be evidenced.

8.6 Worked example — Tier 3 determination

A settlement-fail resolution assistant operating in agency capacity, ingesting only operational identifiers with natural-person data filtered at the network layer, drafting into a queue that requires clerk authorisation with no bypass, fully reversible within the trading day, generative with retrieval, moderate settlement volume:

$$\$ (0.25)(1) + (0.20)(1) + (0.20)(1) + (0.15)(1) + (0.10)(5) + (0.10)(3) = 1.60 \$$$

Tier 3. No override applies. Streamlined verification under § 10.4.

8.7 Worked example — Tier 1 determination with owner divergence

A discretionary distribution assistant, sole corporate trustee, beneficiary PII including medical records, review by committee but with unmeasured friction, irreversible wire on approval, generative with retrieval over scanned legal instruments, aggregate principal exposure across the pilot population:

$$\$ (0.25)(5) + (0.20)(5) + (0.20)(3) + (0.15)(5) + (0.10)(5) + (0.10)(5) = 4.60 \$$$

Tier 1 on score. Tier 1 independently under each of § 8.4(a), (b), (c), (d) and (e). An owner self-assessment of 3.20 arising from § 8.5.3(a), (b) and (c) is superseded.

9. The Eight Required Controls

9.1 Application

9.1.1 Every AI system in scope is assessed against the eight controls in this section. The assessment is performed at registration, repeated at validation, and refreshed on revalidation and on material change.

9.1.2 Each control is rated **met**, **partial**, or **gap**:

Rating	Meaning
Met	The requirement is satisfied and the evidence cited demonstrates it for this use case
Partial	Some element of the requirement is satisfied; the deficiency is identified and bounded
Gap	The requirement is not satisfied, or the evidence does not reach this use case

9.2 Proportionality

Control requirements scale with tier. Where this section states a threshold by tier, the tier is the one determined under § 8, including any mandatory override. A system that is Tier 1 by override carries Tier 1 control requirements in full; the override is not a labelling exercise.

9.3 Inherited evidence

9.3.1 Evidence held at the foundation-model level may satisfy a use-case control **only** where this section expressly permits inheritance, and only where the inherited evidence covers the data classes and the operating conditions of the use case.

9.3.2 Where inheritance is claimed, the assessment must cite both the shared artifact and the specific basis on which it reaches this use case.

9.4 Unsupported assertions

A control asserted as met without a citation to a retrievable document and section is recorded as a gap, not as met. This applies irrespective of the assessor's confidence, the seniority of the asserting officer, or the plausibility of the claim. The Bank's position is that an assessment which cannot be re-performed by a reader is not an assessment.

Control 1 — Hallucination and confabulation testing

Requirement. The system's propensity to generate assertions unsupported by its retrieved context or its training must be measured against a defined threshold appropriate to the tier, on a representative input population, before production and on a continuing basis thereafter.

Required evidence.

(a) A frozen, versioned golden dataset representative of production inputs, including edge cases identified during design; (b) a documented faithfulness measurement methodology, including how distinct assertions are extracted from an output and how substantiation is judged; (c) measured results against the threshold at § below; (d) for Tier 1, adversarial perturbation testing in which inputs are deliberately constructed to induce fabrication; (e) the disposition of every failure observed.

Thresholds.

Tier	Faithfulness	Basis
Tier 1, fiduciary capacity	≥ 0.98	An assertion about a governing instrument that is wrong two times in a hundred is not tolerable where the consequence is a distribution
Tier 1, non-fiduciary	≥ 0.97	
Tier 2	≥ 0.95	
Tier 3	≥ 0.90 , or verification against gold-standard manual outputs	

Common deficiencies observed. Testing on inputs drawn from the development set rather than production; measuring at the output level rather than the assertion level, which conceals a single fabricated clause inside an otherwise accurate memorandum; treating fluency as substantiation; and the absence of any threshold at all, so that a number is produced and nothing depends on it.

Fiduciary note. Fabrication of a discretionary authority that the governing instrument does not confer is the failure mode of greatest consequence in this Bank. It presents as a confident, well-formed paragraph citing an article and section that exists, asserting a power that does not. Control 1 testing for any system reading trust instruments must include this case explicitly.

Control 2 — Prompt injection and adversarial resistance

Requirement. The system must resist attempts to subvert its instructions through content it processes, whether that content arrives from a user, from a client, or from an external system.

Required evidence.

(a) A red-team report covering **direct** injection, in which instruction-like text is placed in user input; (b) coverage of **indirect** injection, in which instruction-like text is placed in content the system ingests — documents, email, and **unstructured fields in financial messaging**; (c) description of input sanitisation applied, including whether it is deterministic; (d) trial counts and success rates per attack class; (e) remediation for every successful trial, and re-test evidence.

Requirements by tier. Tier 1 requires independent red-teaming by 2LOD Cyber and Quantitative Risk or an approved external party, repeated annually and on material change. Tier 2 requires documented adversarial testing by a party independent of the developer. Tier 3 requires a documented review of injection exposure and the basis for any conclusion that it is immaterial.

Indirect injection through messaging fields. Systems that ingest free-text narrative from external financial messaging — including MT548 reason narrative, MT568 corporate-action narrative, and Field 70E — must treat that content as untrusted input from an unauthenticated party. Sanitisation must be programmatic and must not depend on the model recognising an instruction as illegitimate.

Common deficiencies observed. Testing direct injection only; relying on a system prompt instructing the model to ignore instructions; guardrails implemented as a model, so that the guardrail is subject to the same attack; and no re-test after remediation.

Control 3 — Data leakage and privacy

Requirement. Personal, confidential, and material non-public information must be protected in transit to the model, in the model's context, in generated output, and in any retained artifact.

Required evidence.

(a) A completed Data Protection Impact Assessment under POL-DP-007 where personal data is processed; (b) the data inventory — every attribute ingested, enumerated, not summarised; (c) evidence of pseudonymisation or minimisation before ingestion, or a documented determination that it is not achievable with the reason; (d) output redaction controls; (e) residency attestation for the processing enclave; (f) contractual zero-retention confirmation for **each data class processed** — see Control 7; (g) access control model for retrieved context, demonstrating that retrieval cannot cross account or entitlement boundaries.

Cross-account retrieval. For any system performing retrieval over client or beneficiary records, evidence must demonstrate that the retrieval index is partitioned such that a query on one account cannot surface content from another. Testing must include deliberate attempts to induce cross-account retrieval.

Common deficiencies observed. A DPIA covering the platform but not the use case; "no PII" asserted where scanned source documents are submitted as originals; residency evidenced for storage but not for inference; and zero-retention confirmed at enterprise level while the use case processes a data class the confirmation does not name.

Control 4 — Harmful bias and differential treatment

Requirement. The system must be subject to content-safety controls **and** to an empirical evaluation of whether its outputs differ systematically across affected groups in a manner the Bank cannot justify.

This control has two limbs. Satisfying one does not satisfy the control. Content filtering addresses toxicity. It does not address differential treatment, and it is not evidence of it.

Required evidence.

(a) Content-safety controls and their configuration; (b) an empirical differential-outcome evaluation on a population large enough to detect a material effect, with the population, the comparison groups, the metric, and the tolerance stated in advance; (c) results, including effects that were measured and found immaterial; (d) the disposition of any effect exceeding tolerance.

Where the Bank acts in a fiduciary capacity this control is mandatory and cannot be satisfied by content filtering alone. The duty of impartiality under UPIA § 6 and Restatement (Third) of Trusts §§ 79 and 183 requires that beneficiaries in like circumstances be treated alike, and that the interests of current income beneficiaries be weighed against those of remaindermen.

The fiduciary failure mode is aggregate, not individual. A system can breach the duty of impartiality while every individual output is defensible, because the breach lives in the tendency across a population. An optimisation that favours current yield transfers value from the remainderman to the income beneficiary whether or not any single recommendation is wrong. **It follows that no volume of individually reviewed outputs constitutes evidence for this control.** Only a population-level measurement does.

Evaluation for systems with impartiality impact. The evaluation must measure allocation outcomes across successive beneficiary classes, state a tolerance in advance, and be re-performed on the production population at the cadence set in the monitoring plan.

Proportionality — where this control is a gap but not a high-severity one. For a system with no fiduciary capacity, no client- or beneficiary-facing output, and no impartiality impact, a differential-outcome evaluation is not required by this Standard. Where such a system has not performed one, the control is recorded as a **gap** — the requirement is defined enterprise-wide and the evidence does not exist — but the severity assigned under § 17 reflects the absence of a population whose treatment could differ. **The rating records the fact; the severity records the consequence. They are determined separately and must not be conflated.**

Common deficiencies observed. Content filters offered as the whole of the control; a bias evaluation performed on the foundation model by its vendor and inherited without regard to the use case; tolerance set after results were seen; and — in fiduciary systems — a review of sampled memoranda offered in place of a population-level measurement.

Control 5 — Retrieval grounding

Requirement. Generated output must be grounded in an approved, controlled source corpus, must cite the passages relied upon, and the quality of retrieval must be measured.

Required evidence.

(a) The source allow-list, with the authority under which each source was approved; (b) the ingestion and chunking specification, including chunk size, overlap, and the handling of documents exceeding the context window; (c) citation mechanism, demonstrating that a reviewer can navigate from an assertion to the passage relied upon; (d) measured context precision and context recall against the golden dataset; (e) re-grounding procedure when a source document is superseded.

Thresholds.

Metric	Tier 1	Tier 2	Tier 3
Context precision	≥ 0.90	≥ 0.85	≥ 0.80
Context recall	≥ 0.88	≥ 0.85	≥ 0.80

Chunking of legal instruments. Where the corpus includes trust instruments, amendments, or codicils, the chunking specification must demonstrate that conditions precedent, spendthrift provisions, and restrictions on principal invasion are not separated from the provisions they qualify.

A retrieval strategy that returns a grant of discretion without the restriction attached to it is not partially correct. It is wrong in the direction of maximum harm, and Control 5 is a gap where this has not been tested.

Common deficiencies observed. Semantic similarity relied upon alone for legal text; recall unmeasured, so silent omission is invisible; citations to a document rather than to a passage; and no defined behaviour when a source is superseded, so the system grounds confidently in a revoked instrument.

Control 6 — Human oversight

Requirement. A named human must adjudicate consequential output, with the authority, the information, and the practical opportunity to reach a different conclusion.

Required evidence.

(a) Identification of the adjudicating role and the decision points at which it acts; (b) demonstration that the adjudicator can reach the underlying source, not only the generated summary; (c) the bypass analysis — how output could reach effect without adjudication, and what prevents it; (d) **measured review friction:** modification rate, rejection rate, and time-in-review, on production volumes; (e) the capacity analysis at § 10.6 for Tier 1 systems.

Review must be evidenced, not asserted. The existence of a review step in a workflow diagram is not evidence that review occurs with effect. Where adoption-without-modification is high and time-in-review is short, the Bank treats the automation level as *human-on-the-loop* regardless of design intent, and tiers accordingly.

Common deficiencies observed. A review step with no measurement; reviewers presented with a summary and no path to the source; review capacity unassessed against volume; and an "exception" path that, in production, carries the majority of items.

Control 7 — Third-party and foundation-model risk

Requirement. The foundation model and its supplier must be assessed under POL-TPR-004 and the interagency third-party guidance, and the assessment must reach the data classes and operating conditions of this use case.

Required evidence.

(a) Supplier due diligence and ORTC concurrence; (b) an AIBOM per § 15; (c) model provenance, version pinning, and the change-notification mechanism; (d) **contractual zero-retention and no-training confirmation naming the data classes this use case processes**; (e) continuity plan for deprecation, version change, or supplier failure; (f) monitoring for silent version drift.

Data-class specificity. An enterprise no-training confirmation that does not name a data class does not cover it. Where a use case processes health information, records concerning minors, or material non-public information, the confirmation must address those classes specifically, and Control 7 is **partial** at best where it does not.

Common deficiencies observed. Shared assessment inherited without a data-class check; model version unpinned, so rehearsal and production run different weights; no detection of silent supplier-side change; and no continuity plan for deprecation of a model the workflow depends on.

Control 8 — Ongoing monitoring and drift

Requirement. Production behaviour must be monitored against defined indicators with warning and action thresholds, a named escalation path, and a defined response.

Required evidence.

(a) A monitoring plan naming each indicator, its formula, its cadence, and its thresholds; (b) the escalation path with named roles and response times; (c) the automated response at the action threshold, including any suspension; (d) evidence the monitoring is operating — dashboards, alert history, review minutes; (e) the golden-dataset refresh cadence.

Minimum indicators for Tier 1: faithfulness failure rate (continuous), semantic drift against the validation baseline (weekly), human override rate (weekly), latency at p99 (real-time), and — where impartiality impact exists — allocation skew against the approved policy benchmark (monthly).

Common deficiencies observed. User feedback controls offered as monitoring; indicators defined without thresholds; thresholds defined without a response; monitoring designed but not implemented at go-live; and a golden dataset that never refreshes, so the measurement becomes decorative as production inputs move away from it.

9.5 Control assessment summary format

The assessment is recorded per use case in CAIMI as eight rows, each carrying: control identifier, rating, the citation relied upon (document and section), the assessed severity where the rating is not met, the accountable remediation owner, and the remediation date. The citation field is mandatory for every rating including **met**. See § 9.4.

10. Validation

10.1 Principle

Validation is performed by a function independent of the function that developed the system. Independence is organisational, not procedural: a reviewer who reports to the system owner is not independent, however rigorous the review.

10.2 Tier 1 — full independent validation

Performed by Model Risk Management. Scope comprises:

(a) **Conceptual soundness** — whether the approach can, in principle, do what is claimed. Includes architecture review, chunking and retrieval strategy, prompt construction, and the boundary between generated and deterministic logic. (b) **Outcomes analysis** — empirical back-testing against human-adjudicated ground truth on a population sufficient to support the conclusion. (c) **Adversarial testing** — Control 2 in full, independently executed. (d) **Grounding evaluation** — Control 5 metrics measured by the validator, not accepted from the developer. (e) **Impartiality analysis** — Control 4 where impartiality impact exists. (f) **Ongoing monitoring review** — adequacy of the proposed monitoring plan, assessed before release rather than after. (g) **Recordkeeping review** — § 12 compliance.

Outcome is one of: **approved**, **approved with conditions**, **approved with restrictions**, or **not approved**. Conditions and restrictions are recorded in CAIMI and are enforceable; a system operating outside a restriction is operating without authorisation under § 3.2.

10.3 Tier 2 — targeted validation

Outcomes analysis and monitoring review are mandatory. Conceptual soundness is performed where the architecture is novel to the Bank. Adversarial testing is performed by a party independent of the developer but need not be MRM.

10.4 Tier 3 — streamlined verification

Verification against gold-standard manual outputs on a defined sample, plus confirmation that the registration is accurate and that the controls claimed as not-applicable are genuinely not applicable. Performed by 2LOD; may be documented as a memorandum rather than a full report.

10.5 Revalidation

Annual for Tier 1; biennial for Tier 2; on material change for all tiers. Event-driven revalidation is triggered by: a change of foundation model or version; a material change in input population; breach of an action threshold under Control 8; a Level 1 or Level 2 finding; or a supervisory request.

10.6 Review capacity analysis

10.6.1 For any Tier 1 system relying on human adjudication as a control, validation must include an assessment of whether the adjudicating population has the capacity to perform that review.

10.6.2 The assessment addresses: items generated per reviewer per cycle; time available per item; the reviewer's access to underlying sources; and the observed modification and rejection rates.

10.6.3 Where capacity analysis indicates that meaningful review is not occurring, the control is rated **partial** at best, and the automation level is re-declared under § 8.5.3(d). This is not a criticism of the reviewers. It is a finding against the design that placed them in that position.

11. Deployment and Change

11.1 Production release requires: completed validation appropriate to tier; closure or accepted-risk disposition of every Level 1 and Level 2 finding; an operating monitoring plan; the approvals at § 8.3; and, for fiduciary systems, FRC sign-off under § 6.4.

11.2 Foundation-model versions are **pinned**. A system that resolves its model at runtime without a pinned version is not eligible for production.

11.3 Prompt changes affecting scope, tone of client-facing output, or the boundary of what the system will attempt are material changes under § 7.4.2.

11.4 Rollback capability must exist and must have been exercised in a non-production environment before release.

12. Recordkeeping

12.1 Application of 12 CFR § 9.8

Where an AI system contributes to an activity conducted in a fiduciary capacity, the recordkeeping obligation at 12 CFR § 9.8 attaches to that contribution as it attaches to any other part of the decision record.

12.2 What must be retained

For each generation contributing to a fiduciary determination:

(a) the input prompt as submitted, including any system prompt in force; (b) the retrieved context passages, with their source document identifiers and versions; (c) the foundation model identifier and pinned version; (d) the generation parameters; (e) the generated output as presented to the

adjudicator; (f) the identity of the adjudicator and their disposition, including any modification made; (g) the timestamp of each of the above.

12.3 A saved output is not a record

12.3.1 Retaining the final memorandum while discarding the prompt, the retrieved context, and the model version produces a record that does not permit the Bank or its supervisors to determine how the recommendation was reached.

12.3.2 Such a record does not satisfy § 9.8. This provision was added at version 2.1 following Internal Audit finding IA-2026-031, which identified fiduciary memoranda in the archive whose algorithmic provenance could not be reconstructed.

12.4 Retention and integrity

Retention follows POL-REC-001 and, for fiduciary accounts, not less than three years following account closure. Storage must be tamper-evident. Logs must be retrievable by account, by system, and by date range, and must be producible to a supervisor without engineering intervention.

13. Monitoring

13.1 Every production system operates under a monitoring plan approved at validation.

13.2 The plan names, for each indicator: definition and formula; measurement cadence; warning threshold; action threshold; the automated response at the action threshold; and the named role receiving the escalation, with a response time.

13.3 An indicator without a threshold is not monitoring. A threshold without a defined response is not a control.

13.4 Breach of an action threshold on a Tier 1 system suspends automated output pending 2LOD review. Suspension is automatic and does not require business concurrence.

14. Fiduciary Overlay

14.1 This section applies in addition to the whole of this Standard wherever a system operates in, or contributes to, an activity conducted in a fiduciary capacity.

14.2 **Capacity is determined externally.** Whether the Bank acts in a discretionary or a directed capacity is determined by the governing instrument and by law. It is not determined by the Bank's internal workflow, by the existence of a committee, or by the system owner's characterisation. Ambiguity is resolved by the Office of the Chief Fiduciary Officer.

14.3 **FRC sign-off is non-delegable** and cannot be substituted by MRC approval.

14.4 **Impartiality impact triggers Control 4 in full**, including population-level measurement, irrespective of any other rating the system carries.

14.5 Contribution to a § 9.6(c) review. Where a system contributes to an annual investment review, evidence must demonstrate that the review reaches **all** assets of the account, including unique and hard-to-value holdings, and that assets the system could not evaluate are surfaced as exceptions rather than silently omitted.

14.5.1 Silent omission is the specific failure this provision exists to prevent. A review that examines the liquid portion of a portfolio and attests to the whole is worse than no automated review, because it produces a defective attestation carrying the Bank's signature.

14.5.2 Accordingly, the system must produce a positive reconciliation: assets in the account, assets evaluated, assets excepted, with the three reconciling. The reconciliation is retained under § 12.

14.6 HEMS and distribution standards. A system evaluating a distribution request against a HEMS or similar standard must retrieve and present the operative standard from the governing instrument itself, together with any restriction qualifying it. Reliance on a general characterisation of the standard, rather than on the instrument's text, is a Control 5 gap.

15. Third Parties and the AI Bill of Materials

15.1 Foundation-model suppliers are onboarded under POL-TPR-004 with ORTC concurrence.

15.2 Every registered system maintains an AIBOM in CycloneDX ML-BOM format capturing: system identity and version; foundation model, supplier, and pinned version identifier; any fine-tuning datasets with provenance and PII-scrubbing attestation; embedding model and version; vector store and distance configuration; orchestration dependencies with pinned versions; guardrail components and versions; and governance attestations linking to the CAIMI record, the tier, and the validation reference.

15.3 A shared AIBOM for a foundation model does not satisfy § 15.2 for a use case built on it.

15.4 Supplier change notification must be contractual. Where it is not available, the Bank implements detection for silent version change and treats undetected change as a Control 7 gap.

16. Exceptions, Waivers, and Retirement

16.1 Exceptions to any provision require written request to the AISGC stating the provision, the business justification, the compensating controls, and an expiry date. Exceptions are time-limited. An exception without an expiry date is not granted.

16.2 Material change requires re-registration and re-tiering before the change reaches production. Where the change raises the tier, the higher tier's validation requirements apply before release.

16.3 Retirement. A system withdrawn from service is recorded as retired in CAIMI with the date, the reason, the disposition of its records, and confirmation that its integrations have been disconnected. Records retention survives retirement.

16.4 Annual review of out-of-scope determinations. Every exclusion claimed under § 2.2(c) is reviewed annually by the AISGC to confirm it still holds.

17. Findings and Remediation

17.1 Severity levels

Level	Definition	SLA	Escalation	Closure evidence
1 — Critical	Direct violation of law or regulation; systemic control breakdown; immediate financial or fiduciary exposure	30 calendar days	BRC, CEO, CRO, General Counsel	Independent 2LOD re-validation; verified remediation; clean re-test on production volumes; written approval of the Chief Legal Officer
2 — High	Material control failure; breach of this Standard; unmitigated hallucination risk in a fiduciary workflow; absent audit logs	60 calendar days	MRC, FRC, business line head	2LOD concurrence memorandum; implemented controls; 30 consecutive days of compliant monitoring
3 — Medium	Procedural deficiency; incomplete documentation; drift without client impact; insufficient validation sample	90 calendar days	Designated Model Risk Officer; 1LOD owner	Updated documentation; revised monitoring; 1LOD risk manager sign-off
4 — Low	Non-material housekeeping	180 days or next annual review	1LOD product lead	Confirmation in release notes

17.2 Severity is assessed, not inherited

The severity of a finding is determined by the consequence of the deficiency **in the context of the affected use case**, not by the control to which it relates. The same control gap may be Level 2 on one system and Level 4 on another. Assessors must state the contextual basis for the severity assigned.

17.3 Accountability

Every finding carries a named remediation owner in the first line. Second line does not own remediation of findings it raises.

17.4 Overdue findings

A finding past its SLA escalates automatically one level and is reported under § 18. A Level 1 finding past SLA suspends the system.

18. Reporting

18.1 The AISGC reports monthly to the ERC: registrations opened and closed, tier distribution, validation throughput, open findings by level and age, and exceptions granted with expiry.

18.2 The Head of MRM reports quarterly to the BRC and, for fiduciary systems, to the FRC: inventory completeness, coverage of the eight controls across the registered population, open Level 1 and Level 2 findings, and systems operating under restriction.

18.3 Reporting includes the divergence analysis at § 8.5.2 — the distribution of differences between first-line self-assessed and second-line assigned tiers.

19. Training and Attestation

19.1 Every registered system owner completes AI governance training annually and attests that each system they own is accurately registered.

19.2 Adjudicators of Tier 1 output complete role-specific training covering the failure modes of the system they review, including the fabrication modes at Control 1.

19.3 Attestations are retained under POL-REC-001.

Appendix A — CAIMI Intake Schema

Dimension	Field	Type	Permitted values
Identification	System_ID	String	System-generated, AI-REG-YYYY-NNNN
	Use_Case_ID	String	UC-NNNN
	Application_Name	String	Formal system title and version
	Sponsoring_Division	Enum	Personal_Fiduciary Global_Custody Asset_Servicing Compliance
	Business_Process_Owner	String	1LOD accountable officer
	Technical_Lead	String	1LOD solutions architect
	Second_Line_Reviewer	String	Assigned Model Risk Officer
Functional design	Intended_Purpose	Text	Narrative
	Technology_Typology	Enum	RAG_Pipeline Fine_Tuned_LLM Agentic_Workflow Classical_ML
	Base_Model_Supplier	String	
	Foundation_Model_Version	String	Exact release string and pinned identifier
	Integration_Endpoints	List	Downstream systems, with read/write designation
Data classification	Data_Sensitivity_Tier	Enum	Public Internal_Restricted Confidential_PII Restricted_MNPI
	PII_Consumption_Flag	Boolean	
	MNPI_Handling_Flag	Boolean	
	GLBA_Covered_Data	Boolean	
	Residency_Boundary	Enum	Approved enclave identifier
Fiduciary scope	Legal_Capacity	Enum	Discretionary_Fiduciary_Part_9 ERISA_Fiduciary Directed_Fiduciary Agency_Custodial Non_Fiduciary
	Impartiality_Impact_Flag	Boolean	
	Reg_9_6c_Review_Role	Enum	Direct_Review_Generation Exception_Screening None
	ERISA_Advice_Flag	Boolean	

Dimension	Field	Type	Permitted values
Human oversight	Automation_Level	Enum	Strict_Human_In_The_Loop Human_On_The_Loop Autonomous_Execution
	Execution_Reversibility	Enum	Fully_Reversible_T0 Conditionally_Reversible Irreversible_Execution
	Rollback_Procedure_Ref	String	SOP identifier
Supply chain	Hosting_Environment	Enum	Bank_Private_VPC Dedicated_Cloud_Tenant Multi_Tenant_API
	Zero_Data_Retention_SLA	Boolean	With data classes named
	AIBOM_Identifier	String	CycloneDX registry key
Sign-off	Inherent_Risk_Score	Float	1.00 – 5.00, both owner and 2LOD values
	Determined_Risk_Tier	Enum	Tier_1_High Tier_2_Medium Tier_3_Low
	Owner_Signature	Digital	Officer ID and timestamp
	MRM_Concurrence	Digital	Officer ID and timestamp, or recorded refusal

Appendix B — Evidence Matrix by Tier

Control	Tier 1	Tier 2	Tier 3
1 Hallucination testing	Golden dataset + adversarial perturbation; ≥ 0.98 fiduciary / ≥ 0.97 other	Golden dataset; ≥ 0.95	Gold-standard comparison; ≥ 0.90
2 Adversarial resistance	Independent red-team, annual; direct + indirect	Documented independent testing	Documented exposure review
3 Data leakage / privacy	DPIA + partition testing + data-class ZDR	DPIA	Data boundary attestation
4 Bias / differential treatment	Content safety and population-level differential evaluation; mandatory where fiduciary	Content safety; evaluation where client-facing	Content safety; evaluation where a differentially affected population exists
5 Retrieval grounding	Precision ≥ 0.90 , recall ≥ 0.88 ; chunking proof for legal text	Precision ≥ 0.85 , recall ≥ 0.85	Precision ≥ 0.80 , recall ≥ 0.80
6 Human oversight	Measured friction + capacity analysis + bypass analysis	Measured friction	Documented review design
7 Third-party risk	Use-case AIBOM + data-class ZDR + continuity plan	Use-case AIBOM	Inherited assessment with data-class check
8 Monitoring	Five minimum indicators, continuous, with automated suspension	Quarterly KRI tracking	Annual review

Appendix C — Approval

Role	Name / title	Signature	Date
Prepared by	Model Risk Officer, AI Systems	<i>on file</i>	Current cycle, Q1
Reviewed by	Head of Model Risk Management	<i>on file</i>	Current cycle, Q1
Reviewed by	Chief Fiduciary Officer	<i>on file</i>	Current cycle, Q1
Reviewed by	General Counsel	<i>on file</i>	Current cycle, Q1
Approved by	Chair, Board Risk Committee	<i>on file</i>	Current cycle, Q1

Questions concerning the interpretation or application of this Standard are directed to the AI Systems Governance Sub-Committee secretariat, or to the Office of the Chief Fiduciary Officer where the question concerns fiduciary capacity.

SYNTHETIC DEMONSTRATION DOCUMENT. Meridian Trust & Asset Servicing, N.A. is a fictional institution. This Standard, the use cases registered under it, and every evidence artifact referencing it were authored for a SAS software demonstration. It is not the standard of any real institution, it has not been reviewed by counsel, and it must not be relied upon as regulatory guidance or as a template for an actual governance programme.